Software Requirements Specification (SRS)

IT Selaras Workspace — Fondasi Next.js Full-Stack + Supabase

Versi	Status	Tanggal	Target MVP
0.2	Menunggu Review	September 2026	Login → Lihat Task → Tambah/Update Task → Simpan ke Supabase → Aktivitas Tercatat

Perubahan pada v0.2: keputusan kontrol akses (Admin/Owner/Member/Viewer, hak edit task) dirapikan dan disamakan antara deskripsi, matriks permission, dan API; mekanisme session Supabase diverifikasi ulang; permission & activity log dipindah ke Fase 1. Lihat Lampiran D — Riwayat Dokumen.

---

1. Pendahuluan

1.1 Tujuan

Dokumen ini menetapkan kebutuhan fungsional dan non-fungsional untuk fondasi teknis IT Selaras Workspace — aplikasi manajemen project dan task berbasis Next.js (App Router) dan Supabase. Dokumen ini menjadi acuan bagi tim pengembang untuk implementasi dan bagi reviewer untuk verifikasi sebelum development dimulai.

1.2 Ruang Lingkup

Sistem yang dibangun mencakup autentikasi pengguna, manajemen project dan task, kontrol akses berbasis role (Admin/Staff, serta role Owner/Member/Viewer di level project), dan pencatatan aktivitas (audit log). Permission dan activity log dibangun sejak fitur paling awal (bukan ditambahkan belakangan) — lihat Bagian 7.

Prinsip panduan pengembangan:

- Security by design — permission dan audit log dibangun sejak Fase 1, bukan afterthought
- Supabase Row Level Security (RLS) sebagai garis pertahanan kedua, setelah middleware Next.js
- Tidak pernah hanya mengandalkan validitas JWT untuk keputusan akses — status akun & keanggotaan project selalu divalidasi ulang di server (lihat Bagian 5.5)
- Tipe data end-to-end — TypeScript dari database hingga UI
- Incremental & reviewable — setiap tahap menghasilkan sesuatu yang bisa diverifikasi

1.3 Definisi, Akronim, dan Singkatan

Istilah	Definisi
RLS	Row Level Security — mekanisme kontrol akses baris data di level database PostgreSQL/Supabase
JWT	JSON Web Token — format token yang digunakan Supabase Auth untuk merepresentasikan session; bersifat stateless/self-contained
SSR	Server-Side Rendering — rendering halaman di server, digunakan Next.js untuk komponen server
MVP	Minimum Viable Product — target implementasi awal dengan fitur inti minimum
DoD	Definition of Done — kriteria terukur yang menyatakan sebuah fase implementasi selesai

Istilah	Definisi
CRUD	Create, Read, Update, Delete — operasi dasar terhadap data
FR / NFR	Functional / Non-Functional Requirement — kebutuhan fungsional / non-fungsional sistem
Access token	Token JWT berumur pendek (default 1 jam) yang dikirim pada setiap request API
Refresh token	Token berumur panjang, single-use & dirotasi, dipakai untuk menerbitkan access token baru

1.4 Referensi

Dokumen	Link / Keterangan
Supabase SSR Guide (Next.js)	https://supabase.com/docs/guides/auth/server-side/nextjs
Supabase RLS Documentation	https://supabase.com/docs/guides/database/postgres/row-level-security
Supabase Auth Sessions & JWT Expiry	https://supabase.com/docs/guides/auth/sessions
Supabase Auth Admin API (signOut, updateUserById)	https://supabase.com/docs/reference/javascript/auth-admin-updateuserbyid
Next.js App Router	https://nextjs.org/docs/app
Zod Validation	https://zod.dev
Implementation Plan — IT Selaras Workspace	Implementation_Plan_IT_Selaras_Workspace.docx (dokumen terpisah, dilampirkan bersama SRS ini)

1.5 Ikhtisar Dokumen

Bagian 2 menjelaskan deskripsi umum produk. Bagian 3 menetapkan keputusan kontrol akses beserta kebutuhan fungsional ter-ID. Bagian 4 kebutuhan non-fungsional. Bagian 5 kebutuhan antarmuka eksternal, termasuk mekanisme session yang sudah diverifikasi ulang. Bagian 6 model dan kamus data. Bagian 7 matriks ketertelusuran kebutuhan (sekaligus menunjukkan fase mana permission & activity log mulai dibangun). Bagian 8 analisis risiko, Bagian 9 lampiran.

2. Deskripsi Umum

2.1 Perspektif Produk

IT Selaras Workspace dibangun sebagai aplikasi full-stack tunggal menggunakan Next.js 16 (App Router) untuk UI dan API layer, dengan Supabase sebagai backend-as-a-service (Auth, PostgreSQL Database, RLS). Struktur proyek mengikuti feature-based folder structure.

2.2 Fungsi Utama Produk

- Autentikasi pengguna dan pengelolaan session
- Manajemen project (lihat, buat, ubah, hapus, kelola member)
- Manajemen task dalam project (lihat, buat, ubah, update status)
- Kontrol akses berbasis role global (Admin/Staff) dan role per-project (Owner/Member/Viewer)
- Panel administrasi untuk pengelolaan member dan role

- Pencatatan dan peninjauan aktivitas sistem (activity log / audit trail), berjalan sejak fitur paling awal

2.3 Karakteristik Pengguna

Sistem memakai dua lapis role yang saling independen: role global (profiles.role) dan role per-project (project_members.role). Role global Admin selalu menang di atas role project manapun (lihat D1 pada Bagian 3.1).

Role Global	Deskripsi
admin	Full administrative access — melihat & mengelola SEMUA project terlepas dari keanggotaan, mengelola member dan role, melihat audit log.
staff	Operational access — hak aksesnya terhadap project ditentukan oleh role per-project (Owner/Member/Viewer) di bawah ini.
Role per-Project	**Deskripsi**
owner	Delegasi pengelolaan di level project tunggal: edit detail project, kelola member (tambah/hapus), assign/reassign/hapus task dalam project tsb — tanpa perlu jadi Admin global.
member	Bisa melihat project & task, membuat task baru, serta mengedit/mengubah status task yang menjadi tanggung jawabnya (creator atau assignee).
viewer	Read-only — bisa melihat project dan task, tidak bisa membuat atau mengubah apa pun.

2.4 Lingkungan Operasi

- Aplikasi web, diakses melalui browser modern (desktop maupun mobile)
- Frontend & API: Next.js 16 (App Router), TypeScript end-to-end
- Backend: Supabase (PostgreSQL, Auth, RLS); Supabase Storage dan Realtime direncanakan untuk fase lanjutan
- Validasi input: Zod

2.5 Batasan Desain dan Implementasi

Item	Konvensi	Contoh
File komponen	PascalCase	TaskCard.tsx
File utility/lib	camelCase	session.ts
API route	kebab-case folder	/api/audit-logs
Database table	snake_case	activity_logs
Database column	snake_case	created_at, project_id
TypeScript type	PascalCase	TaskStatus, UserRole
Enum value	SCREAMING_SNAKE_CASE	IN_PROGRESS, HIGH

2.6 Asumsi dan Ketergantungan

- Layanan Supabase (Auth, Database) tersedia dan dapat diakses selama development maupun produksi
- Tim memiliki akses ke Supabase dashboard dan dapat menjalankan migration SQL secara berurutan

- Kredensial sensitif (SUPABASE_SERVICE_ROLE_KEY) dikelola hanya di lingkungan server, tidak pernah di client

3. Keputusan Kontrol Akses dan Kebutuhan Fungsional

3.1 Keputusan Kontrol Akses

Tiga pertanyaan desain berikut sebelumnya belum diputuskan secara eksplisit dan menyebabkan ketidakkonsistenan antara deskripsi, matriks permission, dan API. Keputusan di bawah berlaku sebagai acuan tunggal untuk seluruh dokumen ini (SRS) maupun Implementation Plan.

> **D1** Admin dapat melihat dan mengelola SEMUA project, terlepas dari apakah ia terdaftar sebagai member project tersebut atau tidak (bukan hanya project yang ia buat/ikuti).
>
> **D2** Task boleh diedit oleh pembuat (created_by) MAUPUN assignee (assignee_id) — bukan assignee saja. Anggota project lain yang bukan creator/assignee task tersebut tidak dapat mengeditnya.
>
> **D3** Role per-project dibedakan: owner (setara "admin lokal" project — kelola detail project, member, dan semua task di project tsb), member (buat task; edit task miliknya sendiri), viewer (read-only, tidak bisa membuat/mengubah apa pun).
>
> **D4** Role global Admin selalu menang di atas role per-project manapun. Sebaliknya, menjadi owner pada satu project TIDAK memberi akses apa pun ke project lain.

Keempat keputusan ini diterapkan secara konsisten pada Bagian 3.2–3.6 (kebutuhan fungsional & matriks), Bagian 5.2 (API), dan skema RLS pada Implementation Plan.

3.2 Modul Autentikasi & Session

FR-AUTH-01 Sistem harus menyediakan halaman /login dengan input email dan password.

FR-AUTH-02 Sistem harus mengautentikasi pengguna melalui Supabase Auth (signInWithPassword).

FR-AUTH-03 Sistem harus menampilkan pesan error generik saat kredensial salah, tanpa mengungkap detail penyebab.

FR-AUTH-04 Sistem harus mengalihkan pengguna yang belum terautentikasi ke /login ketika mengakses halaman terproteksi.

FR-AUTH-05 Sistem harus menyediakan fungsi logout yang me-revoke refresh token (supabase.auth.signOut()), menghapus cookie, dan mengalihkan ke /login.

FR-AUTH-06 Sistem harus mencatat USER_LOGIN dan USER_LOGOUT ke activity_logs beserta user_id, ip_address, dan created_at — mekanisme ini aktif sejak Fase 1 (lihat Bagian 7).

FR-AUTH-07 Sistem harus menyimpan token session pada HTTP-only cookie melalui @supabase/ssr, bukan di localStorage.

FR-AUTH-08 Sistem harus melakukan refresh access token secara otomatis sebelum masa berlakunya habis.

FR-AUTH-09 Sistem harus memvalidasi profiles.is_active pada setiap request terproteksi di server, terlepas dari apakah access token (JWT) masih tergolong valid secara kriptografis (lihat Bagian 5.5).

3.3 Modul Manajemen Project

FR-PROJ-01 Sistem harus menampilkan daftar project sesuai akses pengguna: Admin melihat seluruh project (D1); Staff hanya melihat project tempat ia terdaftar di project_members (role apa pun: owner/member/viewer).

FR-PROJ-02 Sistem harus membatasi pembuatan dan penghapusan project hanya untuk role Admin.

FR-PROJ-03 Sistem harus mengizinkan Admin ATAU project owner mengubah detail project (nama, deskripsi, status, prioritas, tanggal) (D3).

FR-PROJ-04 Sistem harus mengizinkan Admin ATAU project owner menambah dan menghapus member project (D3).

FR-PROJ-05 Sistem harus menyediakan halaman detail project yang menampilkan informasi project beserta daftar task terkait.

FR-PROJ-06 Sistem harus mencegah Staff yang tidak terdaftar di suatu project mengaksesnya, termasuk melalui akses URL langsung.

3.4 Modul Manajemen Task

FR-TASK-01 Sistem harus menampilkan daftar task dalam suatu project kepada Admin dan seluruh anggota project (owner/member/viewer).

FR-TASK-02 Sistem harus mengizinkan Admin, owner, dan member (bukan viewer) membuat task baru pada project tersebut.

FR-TASK-03 Form pembuatan/pengubahan task harus mewajibkan title dan priority; due_date opsional.

FR-TASK-04 Sistem harus mengizinkan creator ATAU assignee suatu task mengubah status task tersebut (todo → in_progress → review → done/cancelled) (D2).

FR-TASK-05 Sistem harus mengizinkan creator ATAU assignee mengedit task tersebut; member lain yang bukan creator/assignee tidak dapat mengeditnya (D2). Admin dan project owner selalu dapat mengedit semua task dalam cakupannya.

FR-TASK-06 Sistem harus membatasi penghapusan task dan penugasan (assign/reassign) task ke pengguna lain hanya untuk Admin dan project owner.

FR-TASK-07 Seluruh perubahan task harus tersimpan permanen di Supabase dan terlihat setelah halaman dimuat ulang.

FR-TASK-08 Sistem harus mencatat TASK_CREATED, TASK_UPDATED, dan TASK_STATUS_CHANGED (menyertakan nilai lama & baru pada metadata) ke activity_logs — aktif sejak task pertama dibangun di Fase 2, bukan belakangan.

3.5 Modul Administrasi & Role

FR-ADM-01 Sistem harus menampilkan menu "Admin" pada navigasi hanya untuk pengguna dengan role global admin.

FR-ADM-02 Sistem harus mengalihkan akses ke rute /admin/* menjadi redirect ke /dashboard bagi pengguna non-admin.

FR-ADM-03 Sistem harus menyediakan halaman daftar member beserta role dan status aktif/nonaktif.

FR-ADM-04 Sistem harus mengizinkan Admin mengubah role global pengguna (Staff ↔ Admin) dan role per-project (owner/member/viewer) seorang member.

FR-ADM-05 Sistem harus mengizinkan Admin menonaktifkan akun; akun nonaktif tidak dapat login, dan seluruh request dari sesi yang sedang berjalan harus ditolak pada pemeriksaan is_active berikutnya meskipun access token (JWT) belum kedaluwarsa (lihat Bagian 5.5 dan FR-AUTH-09).

FR-ADM-06 Sistem harus mencatat USER_ROLE_CHANGED, USER_ACTIVATED, dan USER_DEACTIVATED ke activity_logs.

FR-ADM-07 Validasi permission harus diterapkan pada tiga lapisan: Next.js middleware, API route/server action, dan Supabase RLS — mekanisme ini dibangun sejak Fase 1 (lihat Bagian 7), terlepas dari antarmuka admin yang baru tersedia di Fase 3.

3.6 Modul Activity Log

FR-LOG-01 Sistem harus menyediakan halaman /admin/audit-logs yang hanya dapat diakses oleh Admin.

FR-LOG-02 Halaman audit log harus mendukung filter berdasarkan user, action, dan tanggal.

FR-LOG-03 Endpoint GET /api/admin/audit-logs harus mendukung pagination.

FR-LOG-04 Activity log bersifat append-only — tidak ada mekanisme update atau delete terhadap entri log, termasuk oleh Admin. Struktur dan mekanisme pencatatan ini aktif sejak Fase 1; FR-LOG-01 s.d. 03 hanyalah antarmuka untuk meninjau data yang sudah terkumpul sejak awal.

FR-LOG-05 Setiap entri log harus mencatat pelaku (user_id), aksi (action), jenis dan ID resource terkait, deskripsi, metadata (JSONB), serta waktu (created_at).

3.7 Spesifikasi Kontrol Akses (Matriks)

Matriks berikut menerapkan keputusan D1–D4 secara konkret per resource.

Projects

Aksi	Admin	Owner	Member	Viewer	Non-member
Lihat project	YES (semua)	YES	YES	YES	NO
Buat project baru	YES	NO	NO	NO	NO
Edit detail project	YES	YES	NO	NO	NO
Hapus project	YES	NO	NO	NO	NO
Tambah / hapus member	YES	YES	NO	NO	NO

> ⚠ **Admin selalu YES pada seluruh project (D1). Owner/Member/Viewer adalah role per-project dari tabel project_members — bukan role global.**

Tasks

Aksi	Admin	Owner	Member (creator/assignee)	Member (lainnya)	Viewer
Lihat task	YES	YES	YES	YES	YES
Buat task baru	YES	YES	YES	YES	NO
Edit task / ubah status	YES	YES	YES	NO	NO
Hapus task	YES	YES	NO	NO	NO
Assign / reassign task	YES	YES	NO	NO	NO

> ⚠ **D2: hak edit/ubah status melekat pada task spesifik (siapa creator/assignee-nya), bukan pada role project secara umum — seorang Member bisa YES untuk satu task dan NO untuk task lain dalam project yang sama.**

User Management (role global — Admin only)

Aksi	Admin	Staff
Lihat daftar member	YES	NO
Invite user baru	YES	NO
Aktifkan / nonaktifkan akun	YES	NO
Ubah role global / role per-project	YES	NO
Hapus user	YES	NO

Audit Logs

Aksi	Admin	Staff
Lihat audit log	YES	NO
Filter audit log	YES	NO
Hapus audit log	NO	NO

> ⚠ **Prinsip: tidak ada role yang dapat menghapus audit log, termasuk Admin — append-only (FR-LOG-04).**

4. Kebutuhan Non-Fungsional

4.1 Keamanan

NFR-SEC-01 SUPABASE_SERVICE_ROLE_KEY tidak boleh diekspos ke kode client-side; ditegakkan dengan aturan ESLint khusus.

NFR-SEC-02 Seluruh tabel database harus mengaktifkan Row Level Security (RLS).

NFR-SEC-03 Session token harus disimpan pada cookie dengan atribut HTTP-only, Secure (di production), dan SameSite=Lax.

NFR-SEC-04 Autentikasi password sepenuhnya didelegasikan ke Supabase Auth; sistem tidak menyimpan password secara custom.

NFR-SEC-05 RLS harus diuji secara eksplisit dengan minimal dua akun berbeda, mencakup kombinasi owner/member/viewer, sebelum setiap merge ke branch utama.

NFR-SEC-06 Sistem TIDAK BOLEH menganggap access token (JWT) yang valid secara kriptografis sebagai bukti akun masih aktif. Status profiles.is_active harus divalidasi ulang di server pada setiap request terproteksi, karena JWT tetap valid hingga waktu kedaluwarsanya sendiri (default ≤ 1 jam) meskipun akun baru saja dinonaktifkan.

NFR-SEC-07 Saat Admin menonaktifkan akun, sistem harus memanggil supabase.auth.admin.signOut(userId, 'global') agar refresh token pengguna tersebut langsung dicabut, mencegah sesi diperpanjang setelah access token berikutnya kedaluwarsa.

NFR-SEC-08 Data project/task pada client harus di-revalidate (refetch) saat halaman kembali difokuskan atau secara berkala, untuk meminimalkan jendela waktu antara pencabutan akses project (D1–D4) dan hilangnya tampilan data usang di client.

4.2 Performa

NFR-PERF-01 Pencatatan activity log harus dilakukan secara asynchronous agar tidak menghambat response utama.

NFR-PERF-02 Kolom yang sering difilter (tasks.project_id, tasks.assignee_id, tasks.status, activity_logs.user_id, activity_logs.created_at, activity_logs.resource_type/resource_id) harus memiliki index database.

4.3 Reliabilitas & Auditabilitas

NFR-REL-01 Setiap tabel harus memiliki kolom created_at dan updated_at dengan default timestamp.

NFR-REL-02 Penghapusan data pada projects dan tasks menggunakan soft-delete (deleted_at), bukan hard delete.

NFR-REL-03 Tipe TypeScript harus di-generate ulang dari skema Supabase setiap kali ada migration.

4.4 Maintainability

NFR-MAINT-01 Struktur folder mengikuti feature-based organization per domain.

NFR-MAINT-02 Seluruh kode mengikuti konvensi penamaan pada Bagian 2.5.

4.5 Usability

NFR-USA-01 Seluruh halaman terproteksi harus menampilkan loading state saat data sedang dimuat.

NFR-USA-02 Seluruh form harus memberi feedback eksplisit untuk kondisi sukses maupun gagal.

NFR-USA-03 Sistem tidak boleh menampilkan halaman crash saat pengguna tidak memiliki akses; harus menampilkan pesan yang jelas (403/404).

5. Kebutuhan Antarmuka Eksternal

5.1 Antarmuka Pengguna

Halaman	Deskripsi
/login	Form login email + password
/dashboard	Ringkasan task yang di-assign ke pengguna yang login
/projects	Daftar project sesuai akses (Admin: semua; Staff: sesuai keanggotaan)
/projects/[id]	Detail project beserta daftar task
/projects/[id]/tasks/new	Form tambah task baru
/projects/[id]/tasks/[taskId]	Detail dan edit task
/admin/members	Kelola anggota & role (khusus Admin) — tersedia mulai Fase 3
/admin/audit-logs	Viewer audit log dengan filter (khusus Admin) — tersedia mulai Fase 4

5.2 Antarmuka API

Endpoint	Method	Deskripsi	Akses
/api/health	GET	Health check koneksi Supabase	Publik
/api/auth/session	GET	Info session pengguna saat ini	Terautentikasi
/api/projects	GET	Daftar project sesuai akses (D1)	Terautentikasi

Endpoint	Method	Deskripsi	Akses
/api/projects	POST	Buat project baru	Admin
/api/projects/[id]	GET	Detail project	Member project / Admin
/api/projects/[id]	PATCH	Update detail project	Admin / Owner (D3)
/api/projects/[id]	DELETE	Hapus project	Admin
/api/projects/[id]/members	POST / DELETE	Tambah / hapus member project	Admin / Owner (D3)
/api/projects/[id]/tasks	GET	Daftar task dalam project	Member project (owner/member/viewer) / Admin
/api/projects/[id]/tasks	POST	Buat task baru	Admin / Owner / Member, bukan Viewer
/api/projects/[id]/tasks/[taskId]	GET	Detail task	Member project / Admin
/api/projects/[id]/tasks/[taskId]	PATCH	Update task (termasuk status)	Admin / Owner / creator-assignee task tsb (D2)
/api/projects/[id]/tasks/[taskId]	DELETE	Hapus task	Admin / Owner
/api/admin/members	GET	Daftar member	Admin
/api/admin/members	POST	Invite user baru	Admin
/api/admin/members/[id]	PATCH	Update role global / status aktif; memicu signOut global jika dinonaktifkan (NFR-SEC-07)	Admin
/api/admin/audit-logs	GET	Daftar audit log (pagination)	Admin

5.3 Antarmuka Perangkat Lunak (Supabase)

Layanan	Kegunaan	Fase
Supabase Auth	Login email/password, session JWT, user management	Fase 1
Supabase Database	PostgreSQL hosted, RLS policies	Fase 1
Supabase JS Client	Query dari browser & server (@supabase/ssr)	Fase 1
Row Level Security	Kontrol akses di level database	Fase 1
Supabase Auth Admin API	signOut(userId,'global') dan updateUserById(ban_duration) untuk pencabutan sesi paksa	Fase 3
Supabase Storage	File attachments	Fase 3+
Supabase Realtime	Notifikasi & activity feed live	Fase 4+

5.4 Mekanisme Session, Cookie, dan Token (Terverifikasi)

Rincian berikut dicek ulang terhadap dokumentasi resmi Supabase (bukan asumsi) agar desain keamanan tidak bergantung pada perilaku yang keliru.

Mekanisme	Penjelasan
HTTP-only cookies	Access & refresh token disimpan oleh @supabase/ssr pada cookie HTTP-only — tidak bisa diakses JavaScript browser (mencegah pencurian via XSS).
Secure flag & SameSite=Lax	Cookie hanya dikirim via HTTPS di production; SameSite=Lax mencegah CSRF untuk sebagian besar skenario.
Masa berlaku access token (JWT)	Default 3600 detik (1 jam); dapat dikonfigurasi di Dashboard > Authentication > Settings > JWT Expiry, maksimum 604.800 detik (1 minggu).
Masa berlaku refresh token	Tidak memiliki expiry waktu tetap selama terus dipakai — bersifat single-use dan dirotasi setiap kali dipakai (refresh token rotation, aktif secara default); token lama berhenti valid setelah jeda reuse-interval singkat (default 10 detik, untuk menoleransi race condition jaringan).
Auto refresh	Client library Supabase otomatis menukar refresh token untuk access token baru sekitar 60 detik sebelum access token kedaluwarsa.
Efek signOut()	Mencabut (revoke) refresh token dan menghapus cookie di client. TIDAK mencabut access token (JWT) yang sudah terbit — JWT tsb tetap valid secara kriptografis sampai waktu kedaluwarsanya sendiri karena sifatnya stateless (lihat 5.5).

5.5 Dampak Perubahan Akses saat Sesi Masih Aktif

Dua skenario berikut wajib ditangani secara eksplisit karena berbeda konsekuensi, mengikuti perilaku Supabase Auth yang telah diverifikasi pada 5.4.

Skenario A — Akun dinonaktifkan (profiles.is_active = false) saat user masih login

- Supabase TIDAK otomatis mencabut access token (JWT) yang sudah terbit begitu is_active diubah menjadi false di tabel profiles — JWT tsb tetap valid secara kriptografis hingga kedaluwarsa (default ≤ 1 jam), karena perubahan pada tabel aplikasi tidak memengaruhi token yang sudah ditandatangani.
- Karena itu sistem TIDAK BOLEH hanya mengandalkan hasil verifikasi JWT. Middleware/session helper (requireAuth()) wajib melakukan query profiles.is_active pada setiap request terproteksi dan menolak akses begitu status nonaktif terdeteksi — bukan menunggu token tersebut kedaluwarsa (NFR-SEC-06, FR-AUTH-09).
- Untuk pemutusan sesi yang lebih cepat/paksa, endpoint penonaktifan akun (PATCH /api/admin/members/[id]) memanggil supabase.auth.admin.signOut(userId, 'global') agar refresh token user tsb dicabut, sehingga user tidak bisa memperpanjang sesi setelah access token berikutnya kedaluwarsa (NFR-SEC-07). Opsional: dikombinasikan dengan auth.admin.updateUserById({ ban_duration }) untuk memblokir percobaan login baru sama sekali.

Skenario B — Akses project dicabut (dihapus dari project_members) saat user masih login

- Berbeda dari Skenario A, RLS dievaluasi ulang oleh PostgreSQL pada SETIAP query database (bukan disimpan di dalam JWT) — sehingga pencabutan keanggotaan project langsung berlaku pada request database berikutnya, tanpa jeda seperti kasus is_active.
- Meski begitu, data yang sudah ter-cache di client (state React, SWR/React Query) bisa saja masih tertampil di layar sampai terjadi refetch berikutnya. Sistem harus melakukan revalidation data project/task saat halaman kembali difokuskan atau secara berkala (NFR-SEC-08), khususnya pada halaman yang menampilkan data sensitif per-project.

> ⚠ **Ringkasan: Skenario A butuh pemeriksaan eksplisit di server (karena token tidak otomatis batal); Skenario B otomatis aman di server (RLS), tetapi butuh revalidation di client.**

6. Model dan Kebutuhan Data

6.1 Prinsip Desain Data

- Semua tabel memiliki id UUID sebagai primary key (default gen_random_uuid())
- Semua tabel memiliki created_at dan updated_at dengan default timestamp
- Foreign key didefinisikan dengan ON DELETE behavior yang eksplisit
- RLS diaktifkan pada seluruh tabel
- Penghapusan data menggunakan soft delete (deleted_at), bukan hard delete

6.2 Diagram Relasi Entitas (Konseptual)

```
auth.users (Supabase built-in)
    |
    | 1:1
    v
profiles
  id (FK --> auth.users.id)
  full_name, display_name, avatar_url
  role: 'admin' | 'staff'          <- role GLOBAL
  is_active, last_login_at
    |
    | 1:N (created_by)          1:N (user_id)          1:N (user_id)
    v                            v                      v
projects                  project_members           activity_logs
  id, name, description     project_id (FK)           user_id (FK)
  status, priority          user_id (FK)              action, resource_type
  created_by (FK)           role: owner|member|viewer resource_id
  start_date, due_date      (role PER-PROJECT)         description
  deleted_at                joined_at                  metadata (JSONB)
    |                                                  ip_address, created_at
    | 1:N
    v
tasks
  id, project_id (FK)
  title, description
  status: todo | in_progress | review | done | cancelled
  priority: low | medium | high | critical
  assignee_id (FK -> profiles)   <- D2: boleh edit
  created_by (FK -> profiles)    <- D2: boleh edit
  due_date, completed_at, deleted_at
```

6.3 Kamus Data

Entitas: profiles

Field	Tipe	Constraint	Deskripsi
id	UUID	PK, FK → auth.users(id), ON DELETE CASCADE	Identitas unik pengguna
full_name	VARCHAR(255)	NOT NULL	Nama lengkap
display_name	VARCHAR(100)	nullable	Nama tampilan
avatar_url	TEXT	nullable	URL avatar
role	TEXT	NOT NULL, DEFAULT 'staff', CHECK IN (admin, staff)	Role GLOBAL pengguna (D4: admin selalu menang)

Field	Tipe	Constraint	Deskripsi
is_active	BOOLEAN	NOT NULL, DEFAULT TRUE	Status aktif akun — dicek di setiap request (NFR-SEC-06)
last_login_at	TIMESTAMPTZ	nullable	Waktu login terakhir
created_at / updated_at	TIMESTAMPTZ	NOT NULL, DEFAULT NOW()	Waktu dibuat / diperbarui

Entitas: projects

Field	Tipe	Constraint	Deskripsi
id	UUID	PK, DEFAULT gen_random_uuid()	Identitas unik project
name	VARCHAR(255)	NOT NULL	Nama project
description	TEXT	nullable	Deskripsi project
status	ENUM project_status	NOT NULL, DEFAULT 'planning'	planning / active / on_hold / completed / cancelled
priority	ENUM priority_level	NOT NULL, DEFAULT 'medium'	low / medium / high / critical
created_by	UUID	NOT NULL, FK → profiles(id)	Pembuat project
start_date / due_date	DATE	nullable	Tanggal mulai / target selesai
deleted_at	TIMESTAMPTZ	nullable	Penanda soft delete
created_at / updated_at	TIMESTAMPTZ	NOT NULL, DEFAULT NOW()	Waktu dibuat / diperbarui

Entitas: project_members (role PER-PROJECT — D3)

Field	Tipe	Constraint	Deskripsi
id	UUID	PK, DEFAULT gen_random_uuid()	Identitas unik baris keanggotaan
project_id	UUID	NOT NULL, FK → projects(id), ON DELETE CASCADE	Project terkait
user_id	UUID	NOT NULL, FK → profiles(id), ON DELETE CASCADE	Pengguna anggota
role	ENUM project_member_role	NOT NULL, DEFAULT 'member'	owner (D3: kelola project & member) / member (buat & edit task sendiri) / viewer (read-only)
joined_at	TIMESTAMPTZ	NOT NULL, DEFAULT NOW()	Waktu bergabung
(project_id, user_id)	—	UNIQUE	Satu pengguna hanya sekali per project

Entitas: tasks

Field	Tipe	Constraint	Deskripsi
id	UUID	PK, DEFAULT gen_random_uuid()	Identitas unik task
project_id	UUID	NOT NULL, FK → projects(id), ON DELETE CASCADE	Project terkait

Field	Tipe	Constraint	Deskripsi
title	VARCHAR(500)	NOT NULL	Judul task
description	TEXT	nullable	Deskripsi task
status	ENUM task_status	NOT NULL, DEFAULT 'todo'	todo / in_progress / review / done / cancelled
priority	ENUM priority_level	NOT NULL, DEFAULT 'medium'	low / medium / high / critical
assignee_id	UUID	FK → profiles(id), ON DELETE SET NULL	D2: boleh edit task ini
created_by	UUID	NOT NULL, FK → profiles(id)	D2: boleh edit task ini
due_date / completed_at	DATE / TIMESTAMPTZ	nullable	Tenggat waktu / waktu selesai
deleted_at	TIMESTAMPTZ	nullable	Penanda soft delete
created_at / updated_at	TIMESTAMPTZ	NOT NULL, DEFAULT NOW()	Waktu dibuat / diperbarui

Entitas: activity_logs

Field	Tipe	Constraint	Deskripsi
id	UUID	PK, DEFAULT gen_random_uuid()	Identitas unik entri log
user_id	UUID	FK → profiles(id), ON DELETE SET NULL	Pelaku aktivitas
action	TEXT	NOT NULL	Kode aksi
resource_type / resource_id	TEXT / UUID	NOT NULL / nullable	Jenis & ID resource terkait
description	TEXT	NOT NULL	Deskripsi human-readable
metadata	JSONB	nullable	Detail tambahan (mis. nilai lama/baru)
ip_address / user_agent	INET / TEXT	nullable	Konteks request
created_at	TIMESTAMPTZ	NOT NULL, DEFAULT NOW()	Waktu kejadian

> **⚠ activity_logs bersifat append-only — hanya SELECT (khusus Admin) dan INSERT yang diizinkan; tidak ada policy UPDATE/DELETE (FR-LOG-04). Mekanisme ini sudah aktif sejak Fase 1.**

6.4 Enumerasi

Enum	Nilai yang Diizinkan
project_status	planning, active, on_hold, completed, cancelled
priority_level	low, medium, high, critical
project_member_role	owner, member, viewer (lihat D3)
task_status	todo, in_progress, review, done, cancelled
role (profiles)	admin, staff (role global — lihat D4)

6.5 Daftar Kode Aktivitas (Action Codes)

```
Autentikasi
  USER_LOGIN / USER_LOGOUT / USER_LOGIN_FAILED / USER_PASSWORD_CHANGED

Task & Project
  TASK_CREATED / TASK_UPDATED / TASK_STATUS_CHANGED (sertakan old/new di metadata)
  TASK_DELETED / TASK_ASSIGNED
  PROJECT_CREATED / PROJECT_UPDATED / PROJECT_DELETED
  PROJECT_MEMBER_ADDED / PROJECT_MEMBER_REMOVED / PROJECT_MEMBER_ROLE_CHANGED

User Management (Admin)
  USER_INVITED / USER_ROLE_CHANGED / USER_ACTIVATED / USER_DEACTIVATED
```

6.6 Indeks Database

Index	Tabel & Kolom	Tujuan
`idx_tasks_project_id`	`tasks(project_id) WHERE deleted_at IS NULL`	Mempercepat query task per project
`idx_tasks_assignee_id`	`tasks(assignee_id) WHERE deleted_at IS NULL`	Mempercepat query task per assignee (D2)
`idx_tasks_status`	`tasks(status) WHERE deleted_at IS NULL`	Mempercepat filter berdasarkan status
`idx_project_members_user`	`project_members(user_id)`	Mempercepat pengecekan keanggotaan & role per-project (D3)
`idx_activity_logs_user_id`	`activity_logs(user_id)`	Mempercepat query log per pengguna
`idx_activity_logs_created`	`activity_logs(created_at DESC)`	Mempercepat sorting/pagination log terbaru
`idx_activity_logs_resource`	`activity_logs(resource_type, resource_id)`	Mempercepat query log per resource

7. Matriks Ketertelusuran Kebutuhan

Matriks ini sekaligus menegaskan keputusan restrukturisasi fase: mekanisme permission (RLS, canDo()) dan activity log dibangun mulai Fase 1, sedangkan antarmuka pengelolaan anggota dan viewer audit log boleh menyusul di Fase 3–4.

ID Kebutuhan	Modul	Fase Implementasi	Prioritas
FR-AUTH-01 s.d. 09	Autentikasi, Session & Validasi is_active	Fase 1	Tinggi (MVP)
FR-PROJ-01 s.d. 06	Manajemen Project (termasuk RLS owner/member/viewer)	Fase 2	Tinggi (MVP)
FR-TASK-01 s.d. 08	Manajemen Task (termasuk aturan creator/assignee)	Fase 2	Tinggi (MVP)
FR-ADM-04 s.d. 07	Mekanisme permission 3-lapis & logging aksi admin	Fase 1–2 (mekanisme)	Tinggi
FR-ADM-01, 02, 03	Antarmuka panel admin (halaman /admin/members)	Fase 3 (UI menyusul)	Sedang

ID Kebutuhan	Modul	Fase Implementasi	Prioritas
FR-LOG-04, 05	Struktur & mekanisme pencatatan log (append-only)	Fase 1	Tinggi
FR-LOG-01, 02, 03	Antarmuka viewer audit log (/admin/audit-logs)	Fase 4 (UI menyusul)	Sedang
NFR-SEC-01 s.d. 08	Keamanan (lintas modul, termasuk is_active & signOut paksa)	Fase 0–3	Tinggi
NFR-PERF-01 s.d. 02	Performa (lintas modul)	Fase 2–4	Sedang
NFR-REL-01 s.d. 03	Reliabilitas Data (lintas modul)	Fase 0–2	Tinggi

Target MVP awal (Bagian 1.2) tercapai dengan menyelesaikan Fase 0 + Fase 1 + Fase 2 — rincian pekerjaan, estimasi waktu, dan cara pengujian tiap kriteria ada pada Implementation Plan (dokumen terpisah, lihat Bagian 1.4).

8. Analisis Risiko

Risiko	Dampak	Mitigasi
RLS tidak dikonfigurasi dengan benar untuk owner/member/viewer	Data leak antar user / project	Test RLS eksplisit untuk ketiga role per-project + Admin, sebelum merge (NFR-SEC-05)
Akun dinonaktifkan tapi JWT lama masih diterima	Mantan user tetap bisa akses hingga 1 jam	Wajib cek is_active di server tiap request + signOut paksa (NFR-SEC-06/07)
Service Role Key ter-expose ke browser	Security breach	ESLint rule: no SUPABASE_SERVICE_ROLE_KEY di client code (NFR-SEC-01)
Type mismatch antara DB dan TypeScript	Runtime error	Generate types dari Supabase setelah setiap migration (NFR-REL-03)
Activity log terlalu verbose / lambat	Performa menurun	Log async, index pada created_at dan user_id (NFR-PERF-01/02)
Admin route tidak diprotect middleware	Unauthorized access	Test: akses /admin/* sebagai Staff harus redirect (FR-ADM-02)

9. Lampiran

Lampiran A — Struktur Folder Project

```
nextjs-stack/
├── src/
│   ├── app/ (auth)/ (dashboard)/ api/
│   ├── components/ ui/ layout/ tasks/ projects/
│   ├── lib/ supabase/ auth/ activity/ validators/
│   ├── types/ database.ts auth.ts task.ts project.ts
│   ├── hooks/ useUser useTasks useProjects
│   └── middleware.ts
├── supabase/ migrations/ seed.sql
└── .env.local / .env.example / package.json
```

Lampiran B — Checklist Kesiapan Development

- Supabase project sudah dibuat (cloud atau local)

- Environment variables sudah dikonfigurasi di .env.local
- Semua anggota tim punya akses ke Supabase dashboard
- Git branch strategy sudah disepakati
- Keputusan D1–D4 (Bagian 3.1) sudah dikomunikasikan ke seluruh tim
- Dokumen SRS ini dan Implementation Plan sudah di-review dan disetujui

Lampiran C — Hubungan dengan Implementation Plan

Dokumen ini (SRS) menetapkan APA yang harus dibangun (requirement, kontrol akses, model data). Rincian BAGAIMANA dan KAPAN — pekerjaan per tahap, urutan pengerjaan, estimasi waktu, serta cara menguji tiap kriteria selesai — didokumentasikan pada Implementation Plan (Implementation_Plan_IT_Selaras_Workspace.docx), dilampirkan bersama dokumen ini.

Lampiran D — Riwayat Dokumen

Versi	Tanggal	Deskripsi Perubahan
0.1	September 2026	Draft awal — disusun dari Implementation Plan IT Selaras Workspace
0.2	September 2026	Menambahkan keputusan kontrol akses D1–D4 (admin lihat semua project, hak edit creator+assignee, arti owner/member/viewer) dan menyamakannya di deskripsi/matriks/API; memverifikasi ulang mekanisme session Supabase (JWT, refresh token, signOut) dan menambahkan penanganan akun dinonaktifkan / akses dicabut saat sesi aktif; memindahkan permission & activity log ke Fase 1 pada matriks ketertelusuran.

Dokumen ini akan diupdate setelah review dan selama proses implementasi.